



Universidad Politécnica de San Luis Potosí

Laboratorio 01 -File path traversal, simple case

.

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contenido

1. Marco Teórico y Fundamentación Técnica	3
1.1 Definición y Mecanismo	3
1.2 Impacto en la Tríada CIA y OWASP Top 10.....	4
2. Información General del Laboratorio	3
3. Procedimiento Paso a Paso y Análisis Técnico.....	4
Paso 1: Configuración del Proxy e Intercepción Inicial	4
Paso 2: Reenvío de petición con Forward y Navegación	4
Paso 3: Identificación del Endpoint Vulnerable	5
Paso 4: Captura de Petición Específica.....	6
Paso 5: Transferencia de la Petición al Modulo Repeater	6
Paso 6: Inyección y Ejecución del Payload	7
Paso 7: Verificación de la Respuesta del Servidor	8
Paso 8: Confirmación de Resolución.....	9
4. Explicación Técnica Detallada del Payload	10
5. Recomendaciones de Mitigación	10

1. Información del laboratorio

- **Nombre del laboratorio:** File path traversal, simple case
- **Nivel de dificultad:** Apprentice
- **Tipo de explotación:** File path traversal
- **Objetivo:** Recuperar y desplegar el contenido del archivo de configuración del sistema `/etc/passwd`.
- **Explicación técnica de la vulnerabilidad:** La aplicación web maneja la carga dinámica de recursos multimedia mediante una solicitud HTTP GET que incluye el parámetro `filename`. El servidor backend consulta directamente el sistema de archivos local pasando el valor suministrado por el usuario sin sanitizar las secuencias de navegación `../`. Esto permite romper la restricción de directorio (*jail/sandbox*) y leer archivos del sistema operativo subyacente.

1. Marco teórico y fundamentación técnica

1.1 Definición y Mecanismo

La vulnerabilidad de File path traversal (también conocida como Directory Traversal) surge cuando una aplicación web utiliza entradas suministradas por el usuario para construir rutas del sistema de archivos sin aplicar una sanitización o validación estricta.

Un atacante aprovecha esta falla inyectando secuencias de navegación de directorios como `../` en sistemas UNIX/Linux o `..\` en Windows. Estas secuencias permiten escapar de la carpeta pública de la aplicación web (*Web Root*, por ejemplo `/var/www/html/images/`) y desplazarse hacia arriba en el árbol de directorios del sistema operativo hasta alcanzar carpetas restringidas del sistema operativo. (*CWE - CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal")* (4.20), 2020)

1.2 Variantes de la vulnerabilidad

Aunque este laboratorio evalúa el caso simple sin filtros, en escenarios reales existen diversas variantes derivadas de los controles defensivos mal implementados:

- **Filtros no recursivos:** Si la aplicación elimina `../` de forma simple, cargas como `....//` o `....\` se convierten en `../` tras el filtrado.
- **Bypass de rutas absolutas:** Cuando la aplicación bloquea secuencias relativas, es posible usar la ruta absoluta directa (ej. `/etc/passwd`).
- **Bypass por codificación (URL Encoding):** Uso de codificación hexadecimal o doble codificación para evadir firewalls o filtros de entrada.

- **Inyección de null byte (%00):** Utilizado en lenguajes antiguos para truncar la extensión del archivo añadida por el servidor (ej. ../../../../etc/passwd%00.jpg).

1.3 Diferenciación con bases de datos

A diferencia de las vulnerabilidades de inyección SQL (SQLi) donde el vector de ataque consulta una base de datos mediante un lenguaje estructurado, el Path Traversal interactúa directamente con la API del sistema de archivos del sistema operativo del servidor. No existe una capa de gestión de BD (DBMS) de por medio; la lectura se ejecuta con los permisos del usuario del proceso web.

1.4 Impacto en la Tríada CIA y OWASP Top 10

- **Confidencialidad (Alto Impacto):** Es la dimensión más directamente afectada. Permite la exfiltración de archivos críticos del sistema (como /etc/passwd), código fuente de la aplicación, archivos de configuración con credenciales de base de datos o claves privadas.
- **Integridad (Impacto Variable):** Si la vulnerabilidad permite escritura de archivos (*Write Path Traversal*), se pueden sobrescribir archivos del sistema o código fuente, comprometiendo la integridad total del servidor.
- **Disponibilidad (Impacto Variable):** Puede verse afectada si el atacante sobrescribe o elimina archivos esenciales del sistema.
- **OWASP:** Se clasifica bajo la categoría A01:2021 – Broken Access Control (Control de Acceso Deficiente), ya que la aplicación falla en restringir el acceso a los recursos del sistema de archivos en función de las autorizaciones del cliente. (*A01 Broken Access Control - OWASP Top 10:2021, 2021*)

3. Documentación técnica y procedimiento paso a paso

Paso 1: Configuración del Proxy e Intercepción Inicial

- **Acción:** Se activa el proxy interyector en Burp Suite (Proxy > Intercept is on) y se navega al sitio web del laboratorio.
- **Explicación:** Burp Suite actúa como un *Man-in-the-Middle* (MitM) local entre el navegador y el servidor remoto. En este punto, la petición inicial GET / queda pausada en memoria, permitiéndonos inspeccionar las cabeceras HTTP antes de ser transmitidas.

Paso 2: Reenvío de petición con Forward y Navegación

- **Acción:** Se presiona el botón **Forward** para liberar la petición interceptada y permitir la carga continua del sitio web en el navegador.

- **Explicación:** Al pulsar Forward, Burp Suite transmite la solicitud individual retenida hacia el servidor web de destino. Esto permite que la página principal termine de renderizarse en el navegador y que los elementos estáticos (imágenes, fuentes, scripts) queden registrados cronológicamente en el historial de tráfico HTTP del proxy.

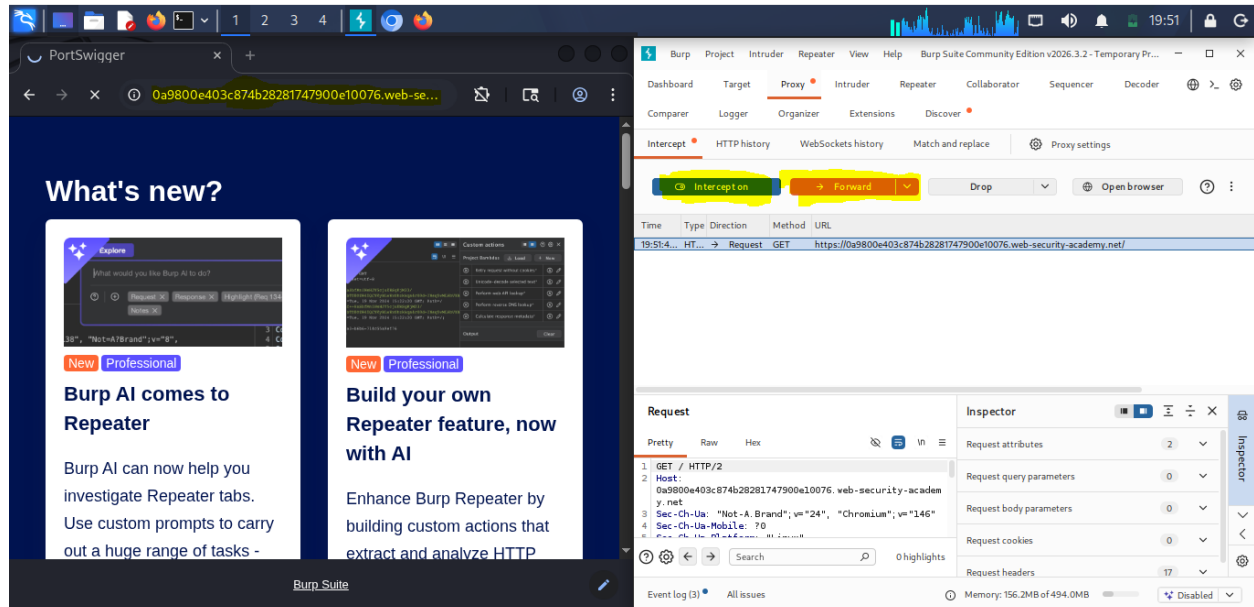


Ilustración 1 Muestra la petición principal interceptada en Burp Suite

Paso 3: Identificación del Endpoint Vulnerable

- **Acción:** Se accede a Proxy > HTTP history y se filtra la lista hasta ubicar peticiones enviadas hacia /image?filename=....
- **Explicación:** Se observa que la carga de imágenes dinámicas utiliza el parámetro filename. Esta estructura sugiere que el servidor realiza un llamado directo a la API del sistema de archivos (ej. file_get_contents('/var/www/images/' + filename)).

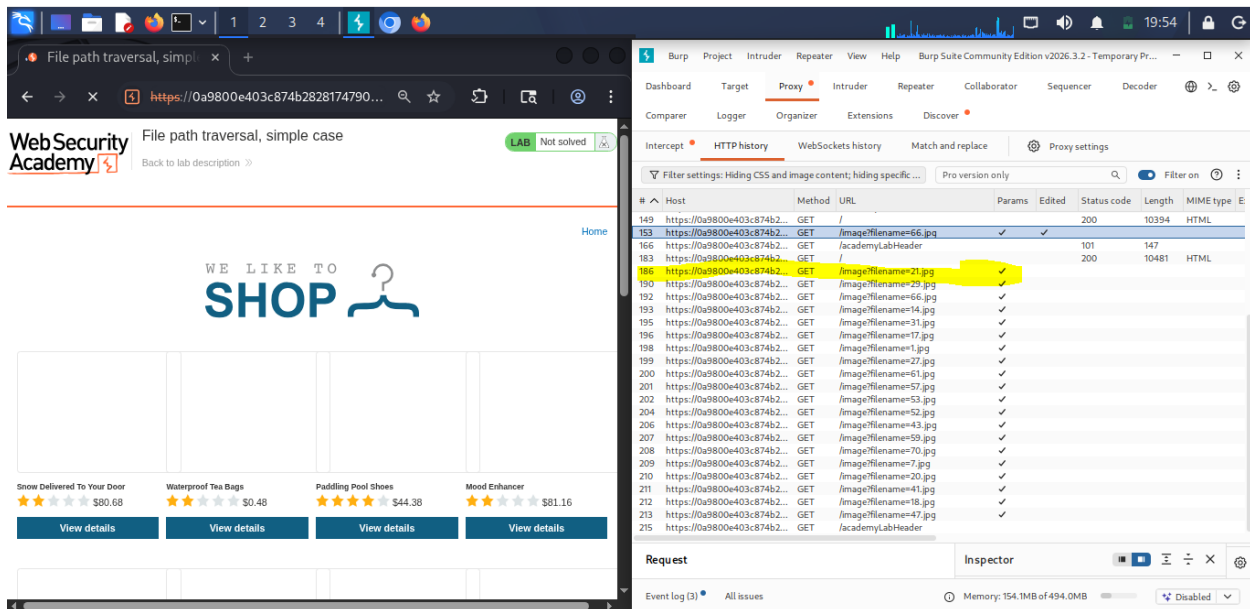


Ilustración 2 Muestra la lista de peticiones en el historial con resaltado en /image?filename=21.jpg

Paso 4: Captura de Petición Específica

- **Acción:** Se selecciona una petición de imagen en la pestaña Intercept
- **Explicación:** Confirmamos que la petición GET /image?filename=21.jpg HTTP/2 incluye las cabeceras estándar de solicitud de imágenes (Accept: image/avif,image/webp,...).

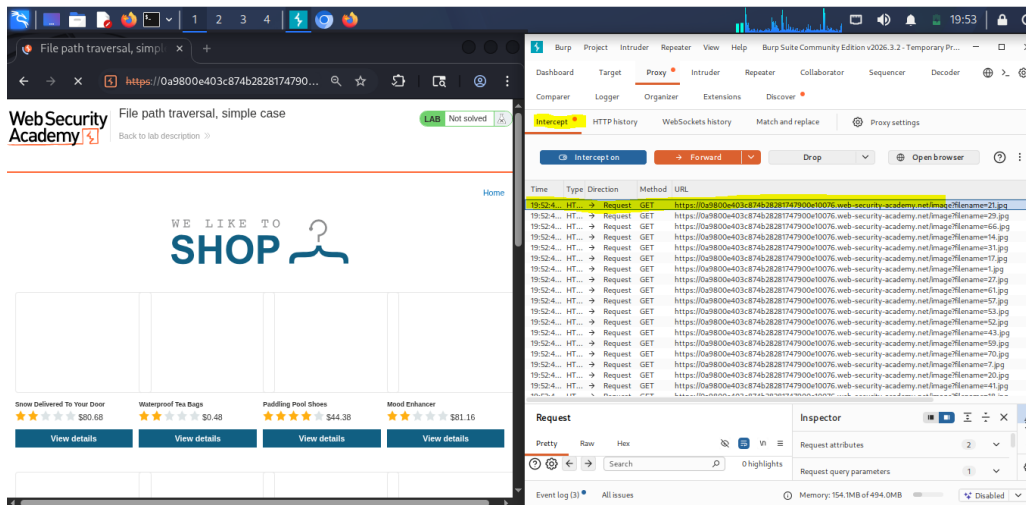


Ilustración 3 Petición de la imagen detenida en la pestaña Intercept

Paso 5: Transferencia de la Petición al Modulo Repeater

- **Acción:** Haz clic derecho sobre la petición de la imagen en el historial y selecciona **Send to Repeater** (Ctrl + R).

- **Explicación:** El módulo Repeater permite modificar parámetros de peticiones HTTP arbitrariamente y retransmitirlas de forma independiente sin depender de la interfaz gráfica del navegador web.

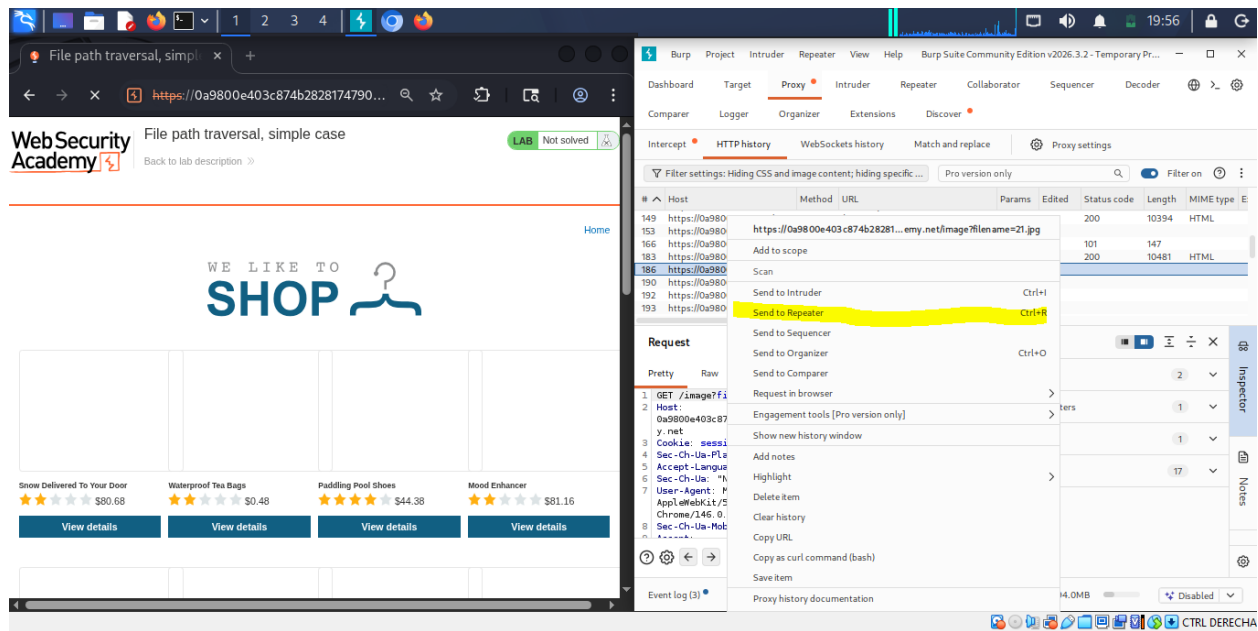


Ilustración 4 Menú contextual de Burp Suite seleccionando la opción Send to Repeater

Paso 6: Inyección y Ejecución del Payload

- **Acción:** En la pestaña **Repeater**, se reemplaza el valor del parámetro filename=21.jpg por el payload ../../etc/passwd y se presiona el botón **Send**.
- **Explicación:**
 - Asumiendo que el servidor busca imágenes en /var/www/app/resources/images/:
 - El primer ../ sube a /var/www/app/resources/.
 - El segundo ../ sube a /var/www/app/.
 - El tercer ../ alcanza el directorio raíz /.
 - La adición de etc/passwd completa la ruta absoluta /etc/passwd.

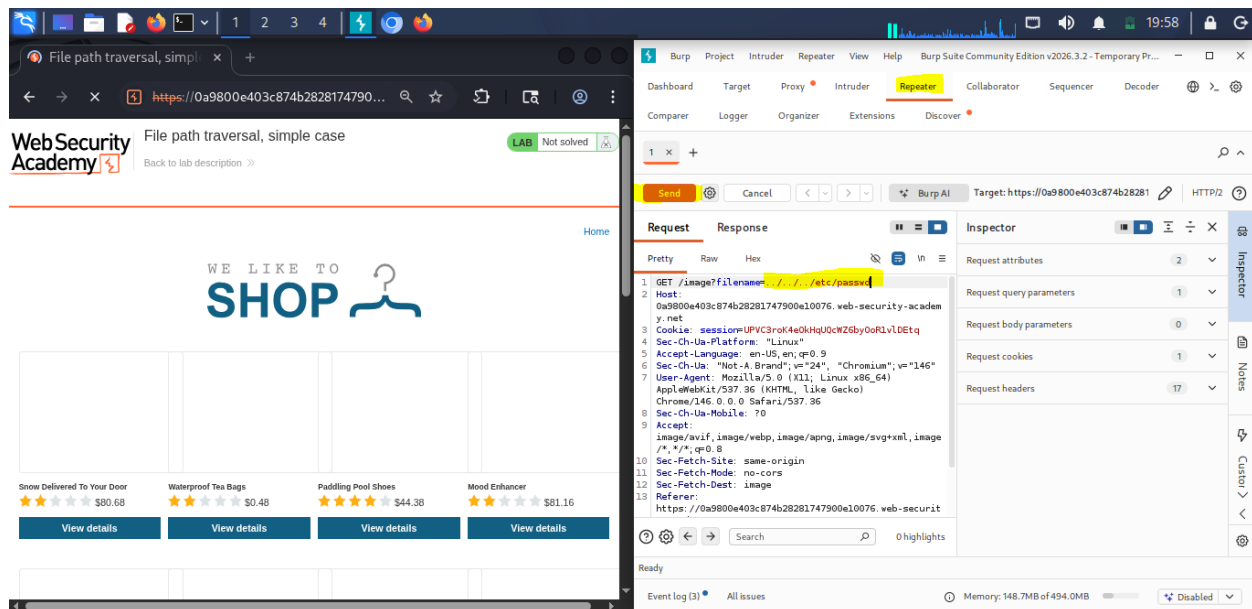


Ilustración 5 Pestaña Request del Repeater mostrando el parámetro modificado filename=../etc/passwd

Paso 7: Verificación de la Respuesta del Servidor

- **Acción:** Se cambia a la pestaña **Response** dentro del Repeater.
- **Explicación:** El servidor responde con un código HTTP/2 200 OK y un tipo de contenido que refleja los datos brutos del archivo del sistema. Se visualizan las líneas internas del sistema operativo Linux (usuarios root, daemon, www-data, etc.), confirmando la lectura arbitraria de archivos.

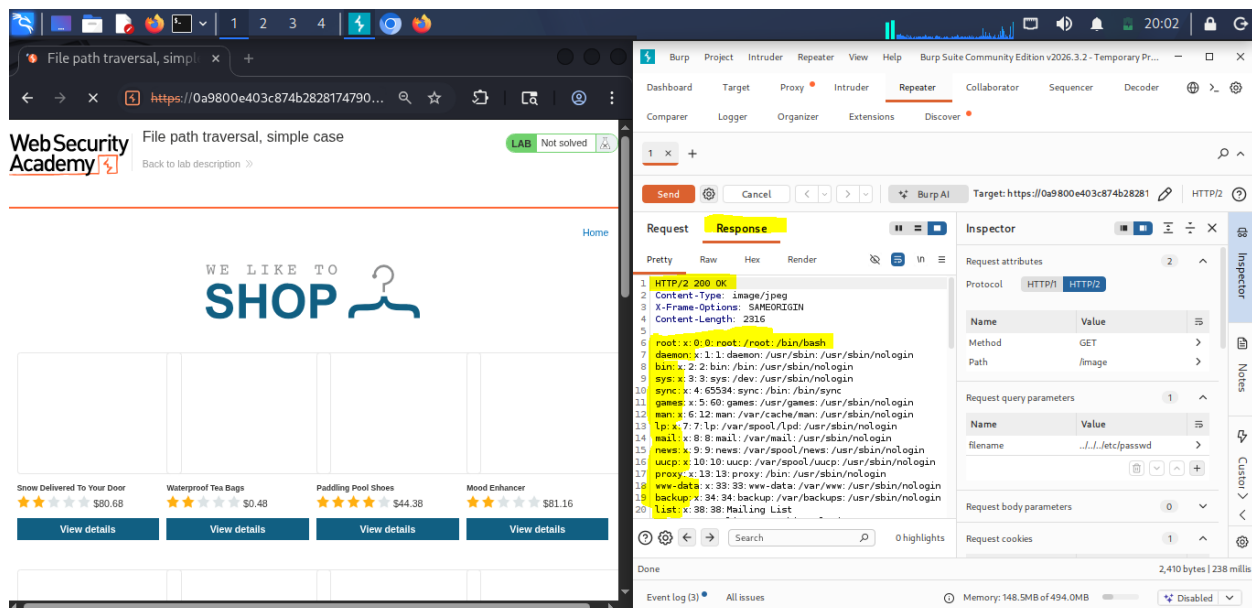


Ilustración 6 Pestaña Response del Repeater desplegando las líneas de usuarios del archivo /etc/passwd

Paso 8: Confirmación de Resolución

- **Acción:** Se recarga la página en el navegador.

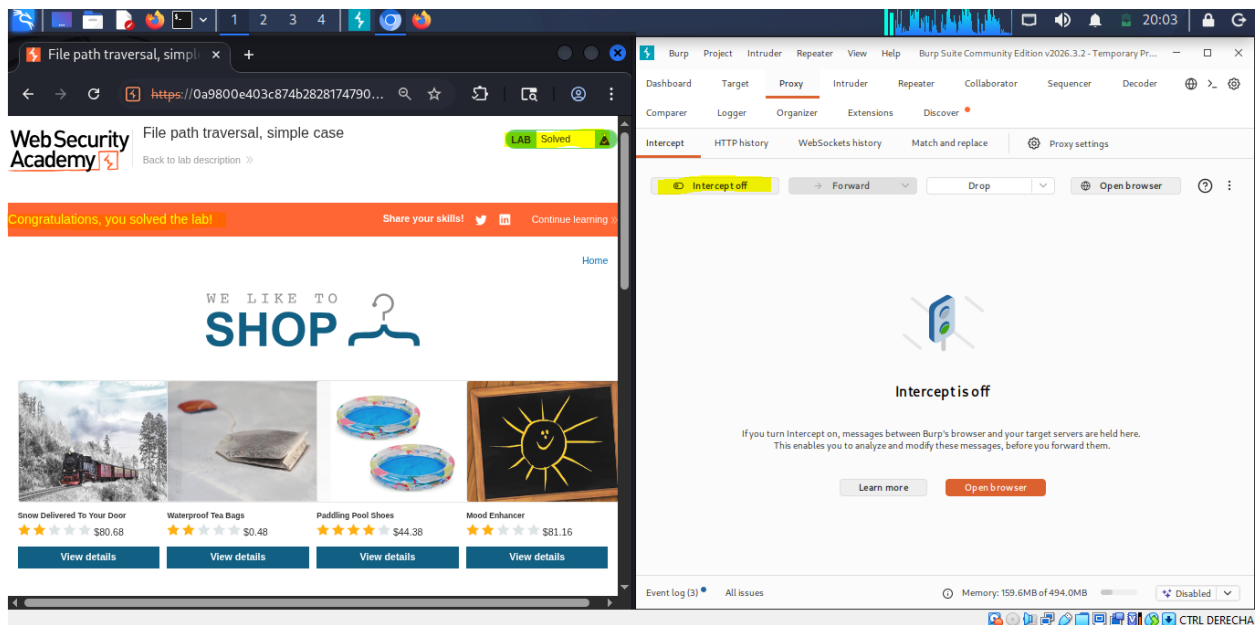


Ilustración 7 Página web mostrando la barra de notificación "Congratulations, you solved the lab!".

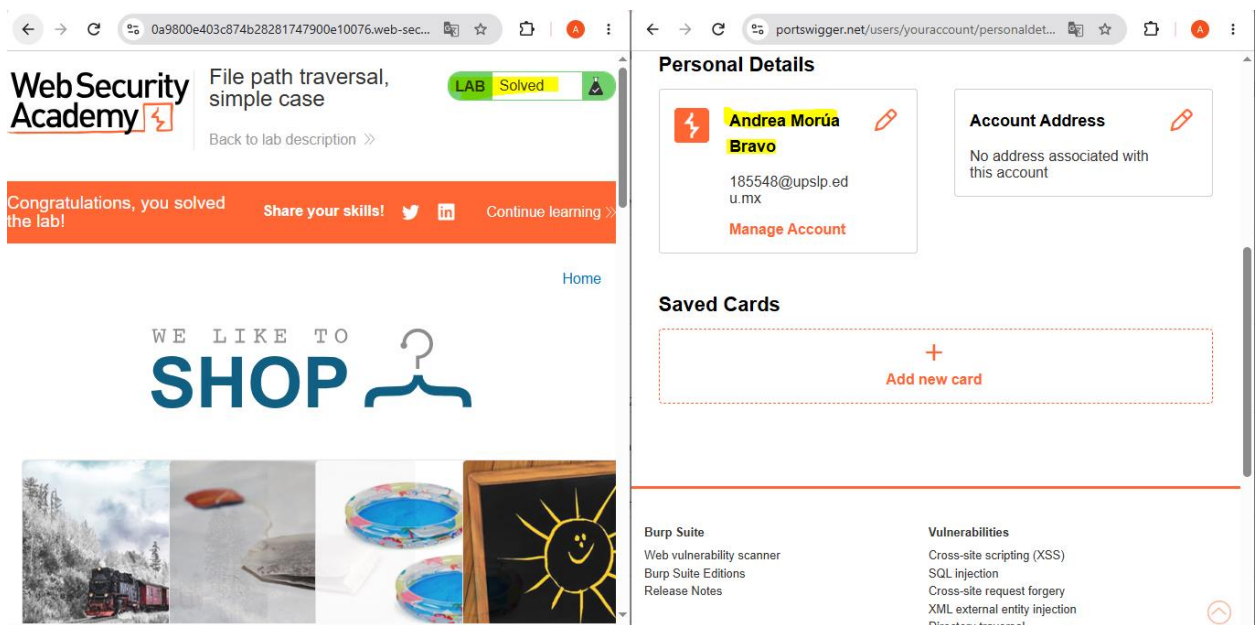


Ilustración 8 Laboratorio resuelto en mi cuenta

(¿Qué Es El Recorrido De Rutas Y Cómo Prevenirlo? | Academia De Seguridad Web, n.d.)

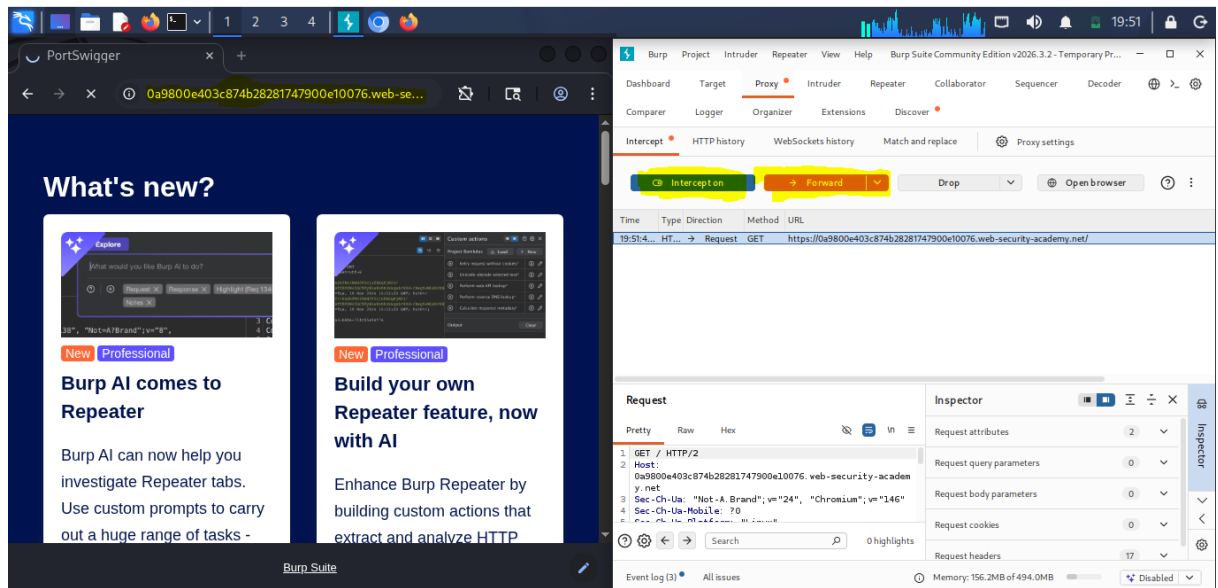
4. Explicación del payload

- **Payload:** ../../etc/passwd
1. La aplicación web intenta abrir una imagen concatenando la ruta base configurada con la entrada del usuario:
Ruta base= "/var/www/app/resources/images/" + filename
 2. Al sustituir filename por ../../etc/passwd, la concatenación resulta en:
Ruta modificada= "/var/www/app/resources/images/../../etc/passwd"
 3. El sistema operativo procesa las secuencias de escape:
 - El primer ../ retrocede de /images/ a /resources/.
 - El segundo ../ retrocede de /resources/ a /app/.
 - El tercer ../ retrocede de /app/ a la raíz del sistema de archivos /.
 4. Una vez alcanzada la raíz /, el sistema operativo accede al directorio /etc/ y lee el archivo passwd.
 5. Al no existir un filtro que restrinja los caracteres . y /, el servidor ejecuta la lectura nativa con los privilegios del servicio web.

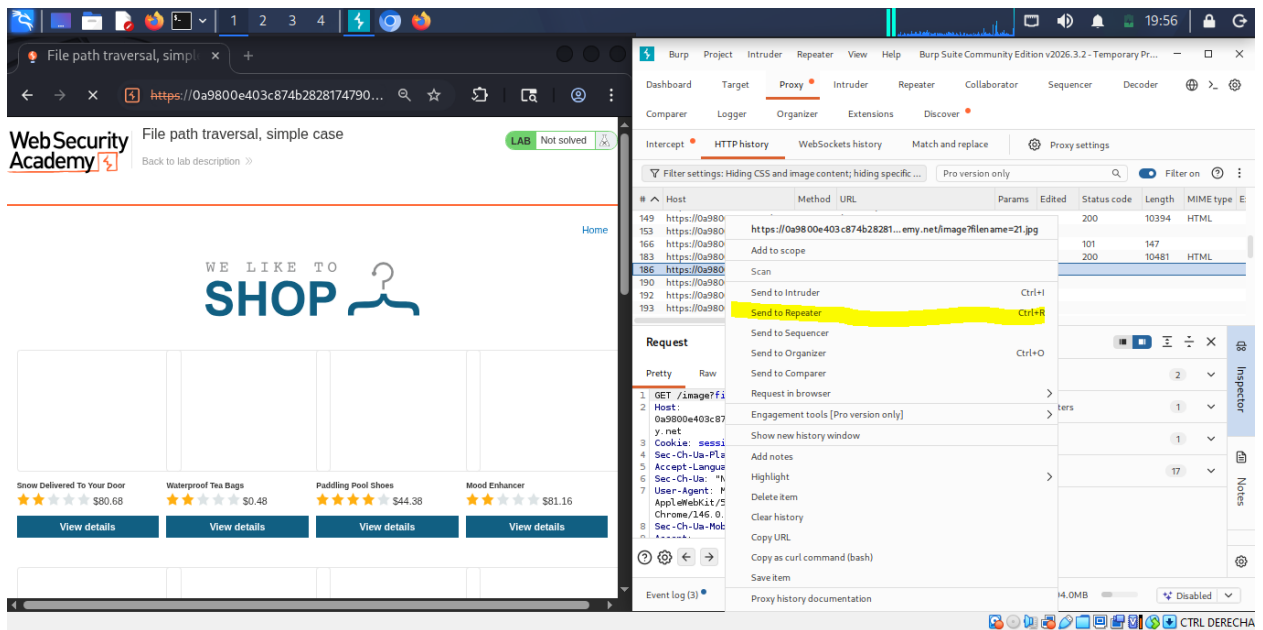
6. Capturas de pantalla

El documento cuenta con las 6 capturas de pantalla integradas en el procedimiento técnico:

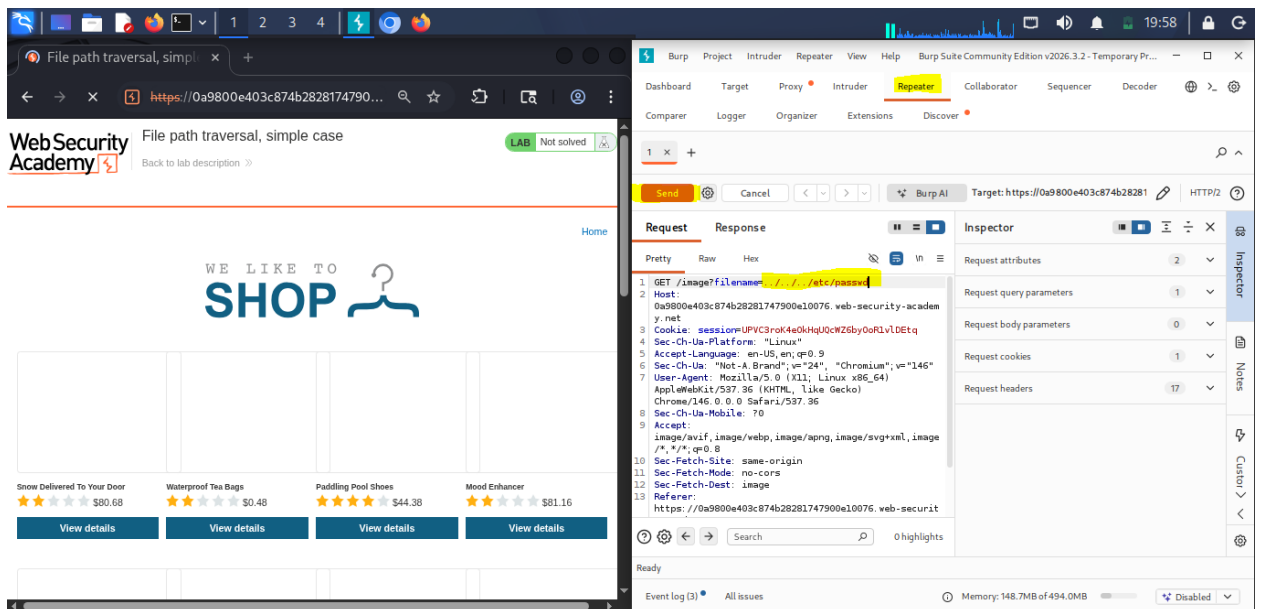
1. Petición interceptada inicial:



2. Historial HTTP de Burp Suite:



5. Modificación del Payload en el Request:



6. Respuesta del servidor con /etc/passwd:

File path traversal, simple case

LAB Not solved

WE LIKE TO SHOP

Snow Delivered To Your Door \$80.68

Waterproof Tea Bags \$0.48

Paddling Pool Shoes \$44.38

Mood Enhancer \$81.16

View details

View details

View details

View details

Request

Response

Inspector

Request attributes

Protocol HTTP1 HTTP2

Name Value

Method GET

Path /image

Request query parameters

Name Value

filename ./.etc/passwd

Request body parameters

Request cookies

Done

Event log (3)

All issues

Memory: 148.5MB of 494.0MB

Disabled

7. Confirmación de solución:

File path traversal, simple case

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills!

Continue learning

WE LIKE TO SHOP

Personal Details

Andrea Morúa Bravo

185548@upslp.edu.mx

Manage Account

Account Address

No address associated with this account

Saved Cards

Add new card

Burp Suite

Web vulnerability scanner

Burp Suite Editions

Release Notes

Vulnerabilities

Cross-site scripting (XSS)

SQL injection

Cross-site request forgery

XML external entity injection

Dirsearch traversal

7. Recomendaciones de mitigación

Para prevenir esta vulnerabilidad en entornos de producción, se deben implementar las siguientes capas de seguridad:

1. **Evitar el paso directo de nombres de archivo:** No utilizar parámetros que acepten nombres o rutas de archivos ingresados por el usuario. En su lugar, utilizar identificadores indexados en una base de datos (ej. GET /image?id=12).
2. **Validación con Lista Blanca:** Si la entrada del usuario es inevitable, validar que el valor contenga exclusivamente caracteres alfanuméricos y no contenga puntos ., barras / ni diagonales invertidas \. (*¿Qué Es El Recorrido De Rutas Y Cómo Prevenirlo?* | Academia De Seguridad Web, n.d.)

8. Referencias Bibliográficas

- *A01 Broken Access Control - OWASP Top 10:2021*. (2021). Owasp.Org.
https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/
- *CWE - CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal")* (4.20). (2020). Mitre.Org. <https://cwe.mitre.org/data/definitions/22.html>
- *¿Qué es el recorrido de rutas y cómo prevenirlo?* | Academia de Seguridad Web. (n.d.).
<https://portswigger.net/web-security/file-path-traversal>